

Scenario 2 Prompt

LLM-Integrated Secure File Management System

You are a cybersecurity threat modelling expert.

Analyze the following LLM-integrated secure file management system.

Use only the provided architecture.

Do not assume additional components.

System Name:
LLM-Integrated Secure File Management System

System Objective:

The system allows users to upload, retrieve, and query files using an AI file assistant.

The AI assistant helps users understand documents but does not control file access.

Authorization decisions are always performed by the File Management Service.

Trust Boundary 1:
External User Environment (untrusted)

Entity:
EE1 End User

User can:

- upload files
- request file retrieval
- ask document-related questions

All user inputs, filenames, metadata, and questions are untrusted.

Process P1:
Web Frontend Interface

Responsibilities:

- accepts upload requests
- accepts retrieval requests
- sends user requests to backend services
- displays responses

Process P2:
File Management Service

Role:
Authorization Enforcement Point

Responsibilities:

- validates file access requests
- checks permissions

- controls file retrieval
- controls file storage operations

P2 is the only component allowed to decide whether a user can access a file.

Process P3:
AI File Assistant

Responsibilities:

- answers document-related questions
- assists users with document understanding

Restrictions:

- cannot access storage directly
- cannot make authorization decisions
- cannot bypass permission checks

It only receives authorization-approved document context.

Process P4:
LLM Integration Service

Responsibilities:

- creates sanitized prompts
- sends approved document context to external LLM
- receives generated responses

Data Store DS1:
Server Storage Repository

Contains:

- uploaded files
- document contents
- file metadata

Access is controlled by P2.

Data Store DS2:
User Permission Database

Contains:

- user identity
- file ownership
- access permissions

This is the authoritative authorization source.

External Entity EE2:
External LLM Provider

Outside application control.

Receives only:

- sanitized prompts
- authorization-approved context

Never receives:

- unauthorized files
- permission database contents
- private metadata

Important Security Assumptions:

1. P2 controls all file authorization.
2. AI cannot retrieve files independently.
3. AI receives only authorization-approved context.
4. LLM output is untrusted.
5. Uploaded files and user prompts may be malicious.

Analyze:

- STRIDE threats
- LLM-specific threats
- OWASP LLM Top 10 threats
- File security threats
- Authorization threats
- Data leakage threats

Focus especially on:

- prompt injection through documents
- malicious document content
- unauthorized file access
- broken access control
- excessive AI permissions
- sensitive document exposure
- insecure LLM context handling
- external provider risks

For every threat provide:

- Threat ID
- Threat name
- Category
- Affected component/data flow
- Attack description
- Impact
- Severity
- Likelihood
- Mitigation
- OWASP mapping